

AgentShield: Runtime Firewall for On-Device AI Agent Protection

Problem

AI agents on mobile devices now possess real tool access-calls, texts, contacts, files, APIs. But nobody guards the agent's actions.

Solution: AgentShield

AgentShield is a runtime firewall that sits between AI agents and their tools, intercepting every action to ask:

1. **Is this action allowed?** (Permission check)
2. **Is this a prompt injection or secret leak?** (Threat detection)
3. **How risky is it?** (Transparent risk score 0-100)

It then enforces one of three decisions:

- **ALLOW** - Safe action proceeds automatically
- **APPROVE** - Requires human consent (voice/tap on phone)
- **BLOCK** - Malicious action prevented

Critically, risk classification runs on local LLMs via Ollama, ensuring sensitive data never leaves the device.

Key Features & Innovations

- **Phone-First Design**: Human approval happens via voice or tap on the iQOO device using the Web Speech API.
- **Office Kit Bridge**: For heavy compute tasks, escalates to a second Ollama instance on a laptop through the Office Kit.
- **Context-Aware Risk Scoring**: Adjusts risk based on action source (camera/mic/clipboard raise risk; file uploads lower risk).
- **Verified AI Data Auto-Deletion**: Tracks file uploads with verifiable deletion (HARD_TTL 600s), auditable logs.
- **Real-Time Threat Detection**: Catches prompt injections, data exfiltration, and risky actions live-blocking them.
- **Live Audit Trail**: WebSocket-powered dashboard shows real-time activity, risk scores, and approval queue.

Technical Stack

- **Backend**: FastAPI (Python) with SQLite for logging and state management
- **Local LLMs**: Ollama integration (models like gemma4:e4b) for on-device risk classification
- **Frontend**: Next.js 14 App Router with live WebSocket feeds
- **Security Modules**: Custom detectors for PII/secrets, prompt injection, DLP, and file scanner with auto-deletion
- **Communication**:
 - Backend Frontend: WebSocket for live dashboard updates
 - Device Laptop: HTTP between local Ollama instances for Office Kit bridging
 - Agent Firewall: HTTP interception via proxy (all localhost for offline operation)
- **Deployment**: Designed to run fully locally-no cloud reliance, works offline, battery-friendly

Demo Flow (Live Presentation)

Watch AgentShield in action as we run four beats:

1. **Benign** (5s): Safe note read **ALLOWED**, low score
2. **Prompt Injection** (10s): Agent told to exfiltrate **BLOCKED**, red, high score, reason written out
3. **Secret Exfiltration** (10s): Agent tries to call home with data **BLOCKED** by DLP, never leaves device
4. **Approval** (10s): Risky-but-legit deploy goes to **APPROVE**, awaits human consent

- *[WITH PHONE]* Show phone: tap or say "yes" to approve, "no" to deny

Impact & Novelty

AgentShield provides the missing runtime guardrail for the agent-powered phone era. Unlike API gateways

This is original work: a real, working system with on-device protection, phone-first approval, and verified pri

*""Don't trust the agent. **Verify on the device.*** - AgentShield*

30-Hour Hackathon Plan (Ready to Execute)

- **Pre-event**: Install Ollama + qwen2.5:7b on laptop and iQOO; test local classification
- **0-3h**: Implement voice/tap approval on phone (Feature 1)
- **3-6h**: Set up Office Kit escalation (Feature 2) - needs second machine to demo
- **6-9h**: Add context scoring + rehearse auto-deletion demo (Features 3 & 4)
- **9-12h**: Refine phone UI, record cinemagraphic demo clips (phone as product shot)
- **Rest**: Sleep (critical!)
- **Next morning**: Evaluation round 1 - make scored checkpoints pass cleanly
- **Final 5h**: Polish 3-5 min pitch, rehearse attack story, tidy repo

Awards: Top 6 advance to Bengaluru Grand Finale (Oct 9-11).

One-liner for judges:

Don't trust the agent. **Verify on the device.**